

容器的开源治理

陶冶 · 2026-08-06

两个层次的问题

交付物中有哪些容器镜像

交付的容器镜像中有哪些组件

交付组件构成

7 个组件中，自有代码仅占 1 个

组件	来源	许可证
ticket-api	自有	自有
ticket-web	派生（第三方 base + 自有层）	混合
redis 7.4	纯第三方	RSALv2 / SSPL /混合
ubuntu 24.04	纯第三方	混合
cert-manager	第三方 Operator	混合
istio 1.30	第三方（服务网格）	混合
grafana 12.3	纯第三方	AGPL-3.0/混合

工作流与各环节工具

本次演讲的路线

环节	主要工具	产物
01 构建	<code>docker build / buildx</code>	镜像
02 扫描	<code>syft</code> 、 <code>trivy</code>	SBOM、许可证报告
03 部署	<code>helm</code> 、 <code>kubectl</code> 、 <code>containerd</code>	运行中的集群
04 打包交付	<code>docker save / skopeo</code> 、 <code>Zarf</code>	离线包

构建

01 单镜像开发

`docker build / buildx` —— 产出镜像层与配置

构建环节：产物与自有层

01 构建



自有层的内容通常分两类，二者在后续环节的可见性完全不同

经包管理器安装

RUN apk add / apt install

在文件系统中留有包数据库记录

直接拷贝文件

COPY vendor/...

不产生任何元数据记录

扫描

02 SBOM 与许可证

syft、trivy —— 产出物料清单与合规依据

扫描环节：主要工具

syft

扫描：包管理、二进制指纹

trivy

扫描：包管理

扫描对象：镜像名与交付物

02 扫描

X `syft <镜像名>`

✓ `syft docker-archive:<tar>`

按镜像名扫描时存在回落路径；

按交付物扫描时，文件不存在即失败，
结果与交付物严格同源。

```
[ryantao@RyanTaodeMacBook-Pro ~ % env -u DOCKER_HOST -u DOCKER_CONTEXT syft redis:7.4-alpine -o syft-json 2>&1 | head -20  
[0005] ERROR failed to fetch latest version: Get "https://toolbox-data.anchore.io/syft/releases/latest/VERSION": EOF
```

COPY 进镜像的文件不进入 SBOM

02 扫描

同一自有层中的两类内容，经 syft 与 trivy 分别扫描后的结果

RUN apk add --no-cache jq

syft ✓ **trivy** ✓

检出 jq 及传递依赖 oniguruma

COPY vendor/tiny-utils.js

syft ✗ **trivy** ✗

两个工具的所有模式均无记录

tiny-utils.js 的文件头声明：Released under the MIT License —— 义务真实存在

经包管理器安装的内容可被检出，直接拷贝的文件不可被检出

默认模式许可证信息需补强

02 扫描

Grafana —— 本次交付中限制性最强的许可证

593

组件被识别

560

无许可证信息

0

次出现 AGPL

Grafana 以 COPY 方式置入镜像的 Go 二进制

不存在可读的包管理器元数据

默认扫描 —— 许可证列为空

☐ 来源	组件	许可证 (生效)	风险	依赖	分发	状态
☐ 包管理	grafana 12.3.1 pkg:generic/grafana@12.3.1	-	未知·推导	传递	未判定	待处理 + 🔍 详情

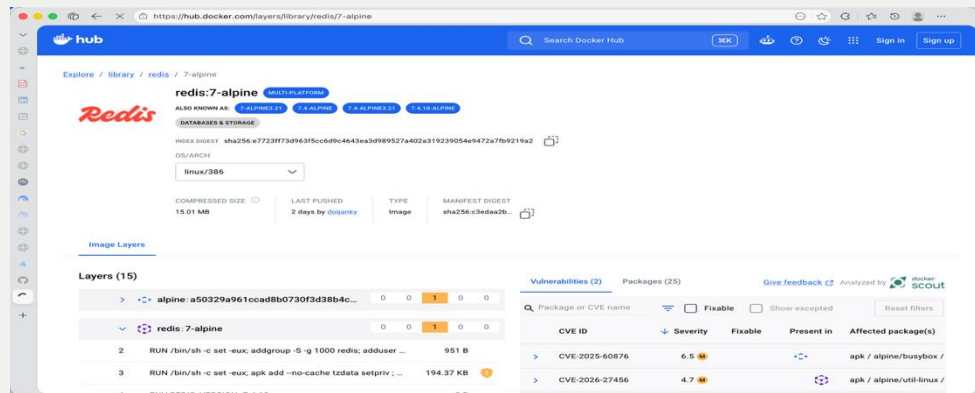
补充扫描后 —— 给出「建议: AGPL-3.0-only」

☐ 来源	组件	许可证 (生效)	风险	依赖	分发	状态
☐ 包管理	grafana 12.3.1 pkg:generic/grafana@12.3.1	- 建议: AGPL-3.0-only AND Others	未知·推导	传递	未判定	待处理 + 🔍 详情

无许可证文本的情况

02 扫描

Redis 7.4 采用 RSALv2 / SSPL



检出的 25 个 package
均为 alpine 系统包
不含 Redis 自身

```
$ find / -iname "*LICENSE*"
-o -iname "*COPYING*"
```

(无输出)

镜像内不存在许可证文件导致Redis本体的扫描结果落空

无许可证文本的情况

[Explore](#) / [Official Images](#) / [emqx](#)



emqx  Docker Official Image · [↓ 5M+](#) · [☆ 108](#)

DEPRECATED; The most scalable open-source MQTT broker for IoT, IIoT, connected vehicles, and more.

MESSAGE QUEUES

[Overview](#)

[Tags](#)

[🔗](#) DEPRECATION NOTICE

Starting from v5.9.0, EMQX has unified all features from the previous Open Source and Enterprise editions into a single, powerful offering with the Business Source License (BSL) 1.1.

If you want to understand why we made the change, please read this [blog post](#) [🔗](#), and if you want to know more about the new license, please read the [EMQX Licensing FAQ](#) [🔗](#).

Consequently, we stopped publishing the `emqx` Docker Official Image. EMQX v5.9.0+ will only be available in the `emqx/emqx` and `emqx/emqx-enterprise` Docker Hub repositories.

Tag summary

Recent tags

latest



Content type

Image

Digest

漏洞噪声

02 扫描

Linux ARM64 镜像中检出 6 个 Windows 可执行文件

```
pip/_vendor/distlib/t32.exe  
pip/_vendor/distlib/t64.exe      w32.exe  
pip/_vendor/distlib/t64-arm.exe  w64.exe  
pip/_vendor/distlib/w64-arm.exe
```

164

全包高危漏洞

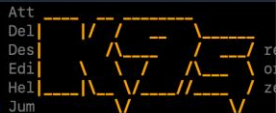
99

Grafana 占比

部署

Context: kind-k8s-multi [RW]
 Cluster: kind-k8s-multi
 User: kind-k8s-multi
 K9s Rev: v0.51.0
 K8s Rev: v1.36.1
 CPU: n/a
 MEM: n/a

<0> all
 <1> default
 <a> Del
 <ctrl-d> Des
 <d> Edi
 <e> Hel
 <?> Jum
 <shift-j>



pods(all)[23]

o s a l [-3]

NAMESPACE	NAME↑↑	PF	READY	STATUS	RESTARTS	IP
cert-manager	cert-manager-689c4c5575-g7qv	●	1/1	Running	2	10.2
cert-manager	cert-manager-cainjector-6fbb9c8cd6-nmznq	●	1/1	Running	2	10.2
cert-manager	cert-manager-webhook-646c95c5ff-2qjmh	●	1/1	Running	2	10.2
default	chatbot-dbcc7d58c-jzg49	●	2/2	Running	4	10.2
default	chatbot-dbcc7d58c-lbdxx	●	2/2	Running	4	10.2
default	chatbot-dbcc7d58c-lzr42	●	2/2	Running	4	10.2
default	chatbot-redis-864d7575d6-4jhv6	●	2/2	Running	4	10.2
default	chatbot-web-547477d86b-rm7rc	●	2/2	Running	4	10.2
kube-system	coredns-589f44dc88-hqg2l	●	1/1	Running	8	10.2
kube-system	coredns-589f44dc88-vh9qg	●	1/1	Running	8	10.2
kube-system	etcd-k8s-multi-control-plane	●	1/1	Running	1	172.
monitoring	grafana-dd569ccd8-t4rp2	●	1/1	Running	2	10.2
istio-system	istiod-9dbccd8b7-8gnrx	●	1/1	Running	2	10.2
kube-system	kindnet-btdlr	●	1/1	Running	8	172.
kube-system	kindnet-phxn2	●	1/1	Running	8	172.
kube-system	kindnet-prlbp	●	1/1	Running	8	172.
kube-system	kube-apiserver-k8s-multi-control-plane	●	1/1	Running	1	172.
kube-system	kube-controller-manager-k8s-multi-control-plane	●	1/1	Running	8	172.
kube-system	kube-proxy-jl7k9	●	1/1	Running	8	172.
kube-system	kube-proxy-jpw7f	●	1/1	Running	8	172.
kube-system	kube-proxy-q8kph	●	1/1	Running	8	172.
kube-system	kube-scheduler-k8s-multi-control-plane	●	1/1	Running	8	172.
local-path-storage	local-path-provisioner-855c7b7774-j9gjk	●	1/1	Running	14	10.2

<pod>

Context: kind-k8s-multi [RW]
 Cluster: kind-k8s-multi
 User: kind-k8s-multi
 K9s Rev: v0.51.0
 K8s Rev: v1.36.1
 CPU: n/a
 MEM: n/a

<a> Attach
 <?> Help
 <l> Logs
 <p> Logs Previous
 <shift-f> PortForward
 <s> Shell



c containers(default/chatbot-redis-864d7575d6-4jhv6)[3]

IDX↑	NAME	PF	IMAGE	READY	STATE	RESTARTS	PROBES(L:R)
I1	istio-init	●	registry.istio.io/release/proxyv2:1.30.3	true	Completed	2	off:off:of
I2	istio-proxy	●	registry.istio.io/release/proxyv2:1.30.3	true	Running	2	off:on:on
M1	redis	●	redis:7.4-alpine	true	Running	2	off:off:of

<pod>

<containers>

Operator

03 部署

Operator 在 CR 出现后才创建工作负载，其镜像名写在 controller 的参数或代码中
在联网集群完整部署并运行业务后，统计节点实际获取的镜像

acmesolver

Operator 处理 ACME 挑战时才创建；本次采用自签证书，该路径未触发

ubuntu 24.04

运维排查用途，按需拉起，常规流程中不出现

打包交付

04 两条路线

docker save / skopeo 与 Zarf —— 产出离线包

打包环节

04 打包交付

	手工路线	Zarf 路线
镜像导出	<code>docker save / skopeo copy</code>	<code>zarf package create</code>
Chart 处理	<code>helm pull / helm package</code>	<code>zarf.yaml</code> 中声明
安装编排	自行编写安装脚本	<code>zarf package deploy</code>
SBOM	自行调用 <code>syft / trivy</code>	内置 <code>syft</code> ，随包产出

镜像名的自动补全

打包过程中，不带 registry 前缀的镜像名被补全为完整路径

zarf.yaml 中声明

```
chatbot-api:v2
```

工具解析结果

```
docker.io/library/chatbot-api:v2
```

该行为源于 OCI 的默认命名规则，
docker、containerd、crane 均如此处理。

纯自有镜像：上游不存在同名，拉取失败
派生镜像：上游存在同名时可能被替换

```
ryantao@RyanTaodeMacBook-Pro scan_result_process % cd /Users/ryantao/local-ai-service/dist/zarf && grep -n -A6 'name: ti
cket-app' zarf.yaml
78: - name: ticket-app
79:   description: "工单系统 (api / web / redis) "
80:   required: true
81:   charts:
82:     - name: chatbot
83:       version: 0.1.0
84:       namespace: default
```

```
[ryantao@RyanTaodeMacBook-Pro zarf % cd /Users/ryantao/local-ai-service/dist/zarf && zarf dev find-images --skip-cosign 2  
>&1 | tail -22  
- name: cert-manager  
  images:  
    - quay.io/jetstack/cert-manager-cainjector:v1.21.1  
    - quay.io/jetstack/cert-manager-controller:v1.21.1  
    - quay.io/jetstack/cert-manager-startupapicheck:v1.21.1  
    - quay.io/jetstack/cert-manager-webhook:v1.21.1  
    # Possible images - cert-manager  
    - quay.io/jetstack/cert-manager-acmesolver:v1.21.1  
- name: istiod  
  images:  
    - registry.istio.io/release/pilot:1.30.3  
- name: grafana  
  images:  
    - docker.io/bats/bats:v1.4.1  
    - docker.io/grafana/grafana:12.3.1  
- name: ticket-app  
  images:  
    - docker.io/library/busybox:1.37  
    - docker.io/library/chatbot-api:v2  
    - docker.io/library/chatbot-web:v1  
    - docker.io/library/redis:7.4-alpine
```

Zarf : find-image

04 打包交付

Zarf 提供的镜像发现能力覆盖到容器启动参数，但不覆盖二级模板

image 字段中的镜像

可发现

Sidecar的镜像 (acmesolver)

可发现，标注为 **Possible images**

Operand的镜像 (proxyv2)

不可发现

```
$ zarf dev find-images -u          # 按发现结果重写 zarf.yaml  
  
< - registry.istio.io/release/proxyv2:1.30.3    # 该行被移除
```

Zarf: find-image

Istio 的 sidecar 在 Pod 创建时注入，其镜像名不出现在 chart 中

```
$ zarf dev find-images --why proxyv2

ERR  unable to find images:
      image registry.istio.io/release/proxyv2:1.30.3
      not found in any charts or manifests
```

Zarf : SBOM

 Zarf SBOM Viewer

docker.io_grafana_grafana_12.3.1

The Zarf SBOM Viewer is deprecated and will be removed in a future release.

Alpine Linux v3.23

Export CSV

20 entries per page

Search...

Type	Name	Version	Sources	Package Files	Notes	Maintainer	Size
npm	@grafana-plugins/grafana-azure-monitor-datasource	12.3.1	1 files	–	Grafana data source for Azure Monitor	–	–
npm	@grafana-plugins/grafana-postgresql-datasource	12.3.1	1 files	–	PostgreSQL data source plugin	–	–
npm	@grafana-plugins/grafana-pyroscope-datasource	12.3.1	1 files	–	Continuous profiling for analysis of CPU and memory usage, down to the line number and throughout time. Saving infrastructure cost, improving performance, and increasing reliability.	–	–

Q & A

实验的完整记录与数据来源可另行提供